

Security Breach Impact Report

1. Executive Summary

This report was written by Andrei S intending to highlight business impact implications followed by a recent security breach. Recently our client, Orion Health Services, has suffered from a security breach. The overall risk of this incident is high and could lead to potential financial losses and interruption of business operations.

2. Incident Overview

Our client is a mid-sized company, mid-sized healthcare technology provider with 250 employees. They manage sensitive patient data and provide cloud-based software to clinics across Australia and New Zealand.

The incident represents a ransomware attack in which attackers encrypt important system files in exchange for large sum of money, threatening user that they would not be able to recover their files if they do not pay the ransom.

The attack was possible through a social engineering technique called phishing. The attackers sent a phishing email to employees of the finance department which contained a malicious Excel file. The internal IT team was able to detect the incident by analyzing unusual outbound traffic to an unknown ip address from a different part of the world.

3. Incident Timeline

We believe the attack started when the employee launched the malicious Excel file. The IT team reported that they detected the activity on Monday morning. Later during the day, several employees reported that they were locked out of their systems and a ransom note appeared on a shared drive.

4. Attack Path / Kill Chain

Initial access was gained by the attacker through an email phishing vector which had attached a malicious Excel file. The attacker then used an open-source security tool called Mimikatz to harvest employees credentials and escalate privileges which gave him access to the shared drive. The shared files were then encrypted and locked behind a paywall by the attacker.

5. Affected Systems and Assets

Important systems and assets were affected by this incident. The internal file server and internal system credentials were compromised by the attacker which could lead to interruption of important business operations since the finance department used these resources to execute operations. Another important asset it that was affected by this attack is the backup server which

was partially encrypted by the attacker. This action could impact business continuity since backing up files from a known good source all important file could not be possible. System credentials were compromised which could led to users not being able to use their systems or accounts until the issue is resolved.

6. Data Impact Assessment

Data that has been affected can be classified into sensitive and critical data. Personal identification information (PII) was compromised, this includes employee payroll records and client appointment schedules, both of which classify as sensitive information. Internal system credential classify as critical data since it could lead to disruption of operational activities. The company could suffer financial and reputation losses as a result of this attack.

7. Operational Impact

Several employees from the finance and HR department were locked out of their devices. File and backup servers became unavailable. These problems could lead to employees not being able to continue their workflows thus impacting customer service and therefore a potential decrease in income for the company could occur.

8. Security Indicators and Evidence

Network sensor detected unusual outbound network traffic to an unknown IP address. An authentication request occurred from a suspicious overseas IP. This could not have happened because none of the employees work from the region of the originating address. Usage of Mimikatz is also an evidence of the attack and requires the use of system admin privileges to run. This means that the attacker was able to compromise a privileged account. User lockout from endpoints and restricted access to normal files is a also evidence of an abnormal system behavior.

9. Root Cause Analysis

This incident succeeded due to the following reasons:

- Weak email security implemented
- Weak employee training on phishing attacks
- Weak endpoint hardening techniques

10. Containment and Response Actions

Actions that must be taken to contain the incident include:

- Locking compromised accounts and enabling MFA
- Isolating compromised systems from the network
- Eradicate malware from compromised systems
- Communicate the incident to stakeholders and other incident response teams

11. Recovery Considerations

Actions that must be taken to recover from this incident include:

- Reset compromised system credentials
- Recover all possible files from the compromised backup server
- Rollback to previous know good versions of the compromised systems

12. Lessons Learned

So far we have learned from this incident that the human factor is a potential risk to an organization and regular user awareness programs should be deployed to better educate users about phishing attempts by malicious threat actors. To further improve the security posture of the organization the following technical security controls should be implemented:

- Geographically restricted employee access to internal resources
- Enable multi-factor authentication
- Deploy email security tools (e.g. DMARC)
- Deploy EDR/XDR for system behavior analysis